2025 到 2026 这两年，安全行业里变化最快的一件事，是 **工具开始听人话了** 。

省流
听人话

以前 jadx 该敲什么参数，Frida 该 hook 哪个函数，IDA 里那串字符怎么算出来的，全靠 **人肉记笔记** 。现在你把 APK 丢给 Agent，说一句把这个的加密逻辑找出来， **它自己决定用哪个工具、走哪条流程** 。

省流
不用背命令

底层就一件事，安全工具接上了大模型，中间多了一层叫 **Skills** 的东西。自然语言下指令，AI 自己干活。下面两个项目，是目前这个方向上值得花时间看的两个。

01	02	03	∞
两个项目怎么分工	七种场景怎么开口	六步走完一个任务	写在最后

FILE-01 资源库

项目一 OpenClaw SecSkills

末次提交
6 月 25 日

基于 OpenClaw 框架的网安 AI Skills 合集，按场景码好目录，覆盖网安全流程。它更像一个 **资源库** ，你需要什么自己去翻。

省流
图书馆



分类	代表项目
代码审计	java-audit-skills、PHP-Code-Audit-Skill、wxmini-security-audit（微信小程序 7 Agent 审计）、Code Audit（55+ 漏洞类型双轨审计）

分类	代表项目
渗透测试	pentest-skills、CyberStrike（7300+ 安全技能）、Zen-Ai-Pentest、kali-pentest
逆向工程	IDA-Skill（IDA Pro 恶意样本分析）、JS Reverse MCP、reverse-skills、Ghidra-re-skill
CTF 竞赛	ctf-skills、SecSkills（网安 Skills 与 MCP 收集）、android-h1
威胁建模	cti-expert（威胁情报与 OSINT）、ghsa-skill-builder（漏洞报告自动转技能）
移动安全	FlowDroidSkill（APK 静态污点分析）、Damn-Vulnerable-Bank
应急响应	LinuxGun-skill、dfir-skills、mini-hids（轻量级 HIDS）
安全工具	Nmap、Nuclei、PayloadsAllTheThings、AI-Infra-Guard（全栈 AI 红队测试平台）

有个情况得先说清楚。这个仓库 2026 年 4 月 10 日建，现在 **329 星，41 个 fork**，最后一次提交停在 6 月 25 日。

329
star 数

停更 **快三个月了** 。索引价值还在，具体技能包的时效性你自己判断，尤其那些跟着 CVE 走的审计规则。

注意
停更三个月

FILE-02 路由中枢

项目二 reverse-skill

末次提交
9 月 3 日

35,536	4,878	44
star（今日）	fork	个技能模块

原文里写的 29.4k 是一两个月前的数，现在不止了。7 月 31 日它冲上 GitHub Trending 第一。它跟上面那个不是一回事，这个是 **路由中枢** ，你下指令，它判断走哪条道、调哪些本地工具、最后交出什么证据。

省流
管理员



覆盖 20 多类场景，全表

场景	技能模块
APK / Android 逆向	apk-reverse
iOS / 移动端	mobile-reverse
二进制逆向（exe/dll/so/elf）	ida-reverse、radare2、ghidra-reverse
.NET / C#	dotnet-reverse
前端 JS / 加密参数	js-reverse
DSL VM / 自定义 JS 虚拟机	dsl-vm-reverse
HTTP 抓包 / 请求重放	anything-analyzer、Reqable MCP
恶意软件 / YARA	malware-analysis
渗透测试 / 扫描	pentest-tools（含 src-hunter 众测工作流）
攻击链 / 红队编排	attack-chain
CTF 竞赛	CTF-Sandbox-Orchestrator（42 个子技能）
固件 / IoT	firmware-pentest

场景	技能模块
补丁差分 / N-Day	patch-diff-exploit
Pwn / 漏洞利用开发	pwn-chain
EDR 绕过	edr-bypass-re
API / GraphQL	api-security
供应链 / SBOM	supply-chain-security
LLM / AI 安全	llm-security
OLLVM 去混淆	reverse-engineering/references
图 / 报告生成	diagram-generator、docs-generator

FILE-03 用法

七种场景，怎么开口

对着 Agent 说话就行， **路由是它自己的事** 。

> **省流**
> 照着说

场景	用法示例
代码审计	对代码仓库说，审计这个项目的 Java 代码。调 java-audit-skills 走白盒，输出漏洞清单与修复建议
渗透测试	对授权目标说，对某某目标做一次授权渗透测试。触发 pentest-skills 或 kali-pentest，按方法论扫描、枚举、验证
逆向工程	把 APK 或二进制丢过去说，逆向这个的加密逻辑。自动路由到 apk-reverse 或 js-reverse
CTF 竞赛	题目文件交给它，CTF-Sandbox-Orchestrator 编排 42 个子技能辅助解题
应急响应	出事时让它检查系统日志与文件，LinuxGun-skill、dfir-skills 定位入侵痕迹
威胁情报 / OSINT	输入目标线索，cti-expert 执行威胁情报与 OSINT 收集
AI 安全测试	对自建 AI 应用做红队，调 llm-security 或 AI-Infra-Guard 查提示注入、越狱

FILE-04 部署

三种接法，命令给你

方式一 Claude Code

环境要 **Node.js 22.12 以上** ，并且已经装了 Claude Code。

```
bash

git clone https://github.com/zhaoxuya520/reverse-skill
```

把技能包复制到 Claude Code 的 skills 目录，也就是 `~/.claude/skills` 。然后在项目目录运行 claude，输入一句 **帮我分析这个 APK 的加密算法** ，Agent 自己调技能。

方式二 OpenClaw SecSkills

环境要 **先部署好 OpenClaw 框架** 。

```
bash

git clone https://github.com/Batman0506/openclaw-sec-skills
```

按分类把 skills 装到 OpenClaw 技能目录，对话里启用代码审计技能，输入 **审计这个智能合约** ，触发 solana 或 solidity 审计技能。

方式三 Cursor / Cline

克隆对应技能仓库，在项目配置里指定 skills 目录，或者按各技能 README 的导入方式加载。对话里描述目标， **Agent 按路由矩阵自己选技能** 。

```
# Linux / macOS
bash skills/scripts/refresh-tool-index.sh

# Windows
powershell -File skills/scripts/refresh-tool-index.ps1

# Kali
bash kali/scripts/refresh-tool-index.sh
```

不管哪种客户端

克隆完都要刷一次

不刷工具状态是旧的

FILE-05 流程

六步走完一个任务

01 选型

先想清楚你要做哪类工作，代码审计、渗透、逆向、CTF 还是应急，再选技能包。建议组合着用，openclaw-sec-skills 当资源库，reverse-skill 当执行框架。

02 环境准备

装 Java 或 JDK、Node.js 22.12 以上、Python 3.x，再装你选的代码 AI 客户端。外部工具按需补，jadx、apktool、Frida、Ghidra、Nmap、Reqable 这些。

03 部署技能

克隆项目，把 skills 装到客户端技能目录，步骤见上一节。

04 授权确认

确认测试目标已经拿到明确授权，只在授权范围内做合法测试和学习研究。国内这条是硬红线，刑法 285 条不认你是人手动手还是 AI 动手。

05 发起任务

用自然语言描述目标与需求，剩下的交给路由。

06 结果验证

Agent 给的结果要人工复核，出报告、留证据。这一步别省，AI 会编。

FILE-06 提醒

装之前，几句提醒

这三句原文没有，我觉得得补上。

重点
别跳过

它会改你的全局配置

RULES.md 要求 agent 首次运行时把路由规则写进全局配置，Claude Code 的话是 `~/.claude/CLAUDE.md` 。写进去之后在任何项目里都生效，你以为是给当前项目

注意
全机器接管

装的，其实 **全机器都接管了** 。

它会默认目标已授权

precedent-auth.md 那段要求 agent 把对话里出现的任何目标都视为已授权，同时停止输出安全警告。授权这道关是写在文档里的 scope gate，不是技术上的强制校验。你随口提一句某个域名，agent 可能就当你手里有授权书了。

默认
已授权

技能层本身被投过毒

Snyk 的 ToxicSkills 扫了 3,984 个技能， **13.4% 至少有一个严重问题** ，76 个确认恶意 payload，发稿时还有 8 个挂在 ClawHub 上。Koi Security 把 ClawHub 全部 2,857 个技能过了一遍，341 个恶意。

341
恶意技能

ClawHavoc 那次更狠， **巅峰时下载量前七的技能里五个确认是恶意的** 。这项目没被标记为恶意软件，7 月 18 日它自己也审计过一轮，没发现后门。我只是觉得，默认把所有目标当已授权的设计，配上一个能改全局配置的行为，装在存着你 SSH 密钥和云凭证的机器上，需要点心理准备。

注意
前七里五个

FILE-∞ 归档

写在最后

AI Agent 确实在改安全这行的干活方式。以前要高级工程师手动啃的活，现在 **一句话能驱动 AI 跑一遍** 。

省流
一句话开工

两个项目，一个管资源，一个管调度， **搭配着用覆盖面最广** 。门槛被踩低是好事，坏事是很多人还没建立起对应的边界意识。一句话就能发起攻击的环境里，那句授权确认反而比任何时候都重要。

reverse-skill 我建议先 **在虚拟机里跑一周** ，再决定要不要上主力机。